

STAJ DEFTERİ

ADI-SOYADI : Gaye Nur Güneş

Gün	27.07.2026 -31.07.2026	Sayfa No
Pazartesi	Git ve GitHub kullanımı, sürüm kontrolü temelleri	5
Salı	Encoding ve Obfuscation, Base64/URL/Hex, CVE-2021-41773/42013, IDOR	6
Çarşamba	Log4Shell, Hashing, hash collision, salt, rainbow table, hashcat	7
Perşembe	Encryption: simetrik (AES) ve asimetrik (RSA/ECC) şifreleme, TLS	8
Cuma	Bilgi güvenliği temelleri, CIA üçlüsü, phishing, ISO 27001	9

Gün	03.08.2026 -07.08.2026	Sayfa No
Pazartesi	Google Dorking, arama operatörleri, lab ve AI kullanım kuralları	10
Salı	OSI ve TCP/IP modelleri, kapsülleme, üçlü el sıkışma, portlar	11
Çarşamba	IPv4 adresleme yapısı, public/private IP, CIDR, loopback	12
Perşembe	Nginx kurulumu, Wireshark ile trafik analizi, Nmap taraması	13
Cuma	Web sitesine bağlanma süreci, ilk ağ trafiği analiz raporu	14

Gün	10.08.2026 -14.08.2026	Sayfa No
Pazartesi	Linux'ta kullanıcılar, izinler (SUID/SGID), süreçler	15
Salı	Linux logları (/var/log), journalctl, log analizi	16
Çarşamba	Windows kullanıcı/grup yapısı, SID, UAC, Event Viewer	17
Perşembe	Sysmon: Process Create, Network Connection, DNS Query	18
Cuma	Log saklama/rotation, SSH analizi uygulaması, SIEM'e giriş	19

Gün	17.08.2026 -21.08.2026	Sayfa No
Pazartesi	Saldırı türleri: brute force, password spraying, phishing, MITM	20
Salı	MITRE ATT&CK: taktik, teknik, alt teknik, lab eşlemesi	21
Çarşamba	Ağ mimarisi: segmentasyon, VLAN, DMZ, proxy, VPN, SIEM	22
Perşembe	Splunk'a veri besleme ve temel SPL sorguları	23
Cuma	Case 1: SSH brute force ve hesap ele geçirme olay raporu	24

<u>İş Yeri</u> <u>Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 27.07.2026 (Pazartesi)
<u>Yapılan iş:</u> Git ve GitHub Kullanımı		
Stajıma başladığım ilk gün, ekip içinde sürüm kontrolü için kullanılan Git ve GitHub araçlarını inceledim. Git'in, yazılım projelerinde kaynak kodun sürüm geçmişini tutan dağıtık bir versiyon kontrol sistemi olduğunu, yapılan her değişikliğin kayıt altına alınmasını, gerektiğinde eski sürümlere dönülmesini ve ekip çalışmasını kolaylaştırdığını öğrendim. GitHub'ın ise Git projelerini internet üzerinde barındıran, kod paylaşımı, Pull Request ve Code Review süreçlerini destekleyen bir platform olduğunu öğrendim. Temel Git komutlarını uygulamalı olarak denedim: git init ile yeni bir depo oluşturdum, git status ile dosyaların durumunu kontrol ettim, git add ile değişiklikleri hazırladım, git commit -m ile bunları kayıt altına aldım. Ardından git branch ve git switch/checkout komutlarıyla farklı branch'ler arasında geçiş yaptım. Son olarak git remote add origin ile yerel projemi GitHub reposuna bağladım, git push origin master ile commit'lerimi gönderdim ve git pull origin master ile güncellemeleri indirdim. Gün sonunda, staj boyunca çalışmalarımı organize bir şekilde kayıt altına alabileceğim bimsen-staj adlı GitHub deposunu oluşturdum ve gün gün klasörleme yapısını kurdum.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		5

<u>İş Yerinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 28.07.2026 (Salı)
<u>Yapılan iş:</u> Encoding, Obfuscation ve Apache Path Traversal Açıkları(CVE-2021-41773/42013)		
İkinci günümde encoding ve obfuscation kavramlarını inceledim. Encoding'in, veriyi herkesçe bilinen bir yöntemle başka bir formata dönüştürme işlemi olduğunu; amacının veriyi gizlemek değil, farklı sistemlerin onu doğru okuyabilmesini sağlamak olduğunu ve bu yüzden anahtar gerektirmediğini öğrendim. Obfuscation'ın ise karmaşıklıklaştırma/gizleme anlamına geldiğini, kaynak kodunu tersine mühendisliğe karşı zorlaştırmak için kullanıldığını, ancak güçlü bir güvenlik yöntemi olmadığını kavradım. Base64 (ikili veriyi metne çevirme), URL Encoding (özel karakterleri %hex formatına çevirme), Hex Encoding ve ASCII/UTF-8 karakter kodlamalarını örnekleriyle çalıştım; küçük bir Base64 encode/decode uygulamasında "Merhaba" kelimesinin TWVyaGFhYQ== şeklinde kodlandığını ve geri çözülebildiğini gördüm. CVE-2021-41773 ve CVE-2021-42013 olaylarını araştırdım; Apache HTTP Server 2.4.49/2.4.50'deki path traversal ve bazı durumlarda RCE açıklarının, sunucunun URL'deki özel karakterleri yanlış işlemesinden kaynaklandığını, ilk yamanın eksik kalması nedeniyle ikinci CVE'nin ortaya çıktığını öğrendim. Son olarak endpoint kırılımı ve IDOR (Insecure Direct Object Reference) kavramlarına baktım: bir kullanıcının yalnızca URL'deki ID değerini değiştirerek başka kullanıcının verisine yetkisiz erişebildiğini kavradım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		6

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 29.07.2026 (Çarşamba)
<u>Yapılan iş:</u> Log4Shell Zafiyeti ve Hashing Kavramı		
Üçüncü gün Log4Shell zafiyetini ve hashing kavramını inceledim. Log4j kütüphanesindeki JNDI arama işleminin hatalı işlenmesinden kaynaklanan bu açığın, saldırganın log'a düşecek bir alana özel bir JNDI dizesi göndererek uzak sunucudan kötücül kod çektirip çalıştırabilmesine imkân verdiğini, bu yüzden 10 üzerinden 10 CVSS puanı aldığını öğrendim. Hashing'in, değişken boyuttaki veriyi sabit uzunlukta benzersiz bir değere dönüştürdüğünü, tek yönlü ve çakışmaya dirençli olması gerektiğini kavradım; MD5 ve SHA-1'in artık güvenli sayılmadığını, SHA-256'nın tercih edildiğini öğrendim. Encoding ile hashing'in amaç bakımından tamamen farklı olduğunu; hashing'in geri döndürülemez ve bütünlük odaklı olduğunu gördüm. Bu yüzden parolaların neden Base64 ile değil hashing ile saklanması gerektiğini anladım: Base64 anahtar gerektirmediği için veritabanı sızarsa saniyeler içinde çözülebilir. Veri bütünlüğü türlerini, hash collision kavramını ve gerçek dünya örneklerini (Flame/Skywiper 2012, SHattered saldırısı, LinkedIn 2012 sızıntısı) inceledim. Salt kavramının Rainbow Table saldırılarını nasıl etkisiz kıldığını, Hashcat'in GPU hızlandırmasıyla parola kırma sürecini nasıl hızlandırdığını öğrendim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		7

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 30.07.2026 (Perşembe)
<u>Yapılan iş:</u> Simetrik/Asimetrik Şifreleme ve TLS		
Dördüncü günümde şifreleme (encryption) konusuna odaklandım. Encryption'ın amacının veriyi yetkisiz kişilerin okuyamayacağı hale getirerek gizlilik sağlamak olduğunu; plaintext, key ve ciphertext kavramları arasındaki ilişkiyi çalıştım. Symmetric encryption'da (AES) tek bir anahtarın hem şifreleme hem çözme için kullanıldığını; DES'in artık güvensiz, 3DES'in güvenli ama yavaş, AES'in ise günümüz standardı olduğunu öğrendim. OpenSSL ile bir metin dosyasını AES ile şifreleyip anahtarla tekrar açtım; CyberChef'te aynı bloğun tekrarlandığı bir metni ECB ve CBC modlarında şifreleyip ECB çıktısında tekrar eden blokların görüldüğünü gözlemledim - bu, Adobe'nin 2013 sızıntısında ECB modunun neden milyonlarca parolanın çözülmesine yol açtığını somutlaştırdı. Asymmetric encryption'da (RSA/ECC) public/private key ayrımını, ECC'nin RSA'ya göre çok daha kısa anahtarla aynı güvenliği sağladığını inceledim. OpenSSL ile bir RSA anahtar çifti üretip public key'i ayrı dosyaya çıkardım. Dijital imzanın, gönderenin kimliğini ve mesaj bütünlüğünü doğrulamayı amaçladığını, private key ile imzalanıp public key ile doğrulandığını öğrendim. Diffie-Hellman'ın iki tarafın gizli anahtarı ağ üzerinden hiç göndermeden ortaklaşa hesaplamasını, TLS'in bu yüzden hem asimetrik hem simetrik şifrelemeyi bir arada kullandığını kavradım. Bir HTTPS sertifikasını .cer olarak dışa aktarıp certutil -dump ile inceledim. Son olarak Heartbleed (2014), WEP'in kırılması, KRACK (2017) saldırısı ve bu yüzden WPA3'e geçiş, "Harvest Now, Decrypt Later" tehdidi ve Perfect Forward Secrecy kavramlarını araştırdım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		8

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 31.07.2026 (Cuma)
<u>Yapılan iş:</u> Bilgi Güvenliği Temelleri ve CIA Üçlüsü		
Beşinci günümde bilgi güvenliğinin temel kavramlarını ele aldım. Bilgi güvenliği ile siber güvenlik arasındaki farkı; ilkinin her türlü ortamdaki bilgiyi, ikincisinin özellikle dijital alandaki veri ve sistemleri kapsadığını öğrendim. CIA üçlüsünü - gizlilik, bütünlük, erişilebilirlik - günlük hayattan örneklerle pekiştirdim. Phishing'in tanımını ve üç türünü (e-mail phishing, spear phishing, whaling) araştırdım. ISO 27001 standardının, kurumların bilgi güvenliğini CIA prensiplerine uygun şekilde yönetmesini sağlayan bir yönetim sistemi standardı olduğunu, güvenlik politikaları oluşturma ve çalışan farkındalığı artırma rollerini inceledim. İki farklı kurumun Clean Desk / Clear Screen politikalarını karşılaştırarak masada ve bilgisayarda dikkat edilmesi gereken dört temel kuralı (ekran kilitleme, belgelerin güvenli saklanması, parolaların gizliliği, gün sonu temizliği/imha) çıkardım. Son olarak uzaktan çalışırken karşılaşılabilecek beş kritik güvenlik riskini (phishing/sosyal mühendislik, zayıf parolalar, güvensiz ağlar, MFA eksikliği, kişisel cihazlardan çalışma) ve her biri için alınabilecek en basit önlemi (farkındalık eğitimi, parola yöneticileri, VPN, çok faktörlü kimlik doğrulama, kurumsal cihaz kullanımı) listeledim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		9

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 03.08.2026 (Pazartesi)
<u>Yapılan iş:</u> Google Dorking ve Staj Kuralları		
Altıncı günümde Google Dorking tekniğini inceledim. Bunun, web tarama veya kaba kuvvet gibi aktif yöntemlerin aksine tamamen pasif bir teknik olduğunu, kuruluşların açığa çıkarmayı amaçlamadığı ama herkese açık şekilde indekslenmiş dosya, izin ve giriş sayfalarını özel arama operatörleriyle ortaya çıkardığını öğrendim. site: (belirli bir sitede arama), filetype: (belirli dosya türlerini arama), intitle: (sayfa başlığında arama - örneğin "index of" ile izin listelemesi açık sunucuları bulma), inurl: (URL içinde arama), tırnak içinde tam eşleşme arama, - ile hariç tutma ve OR operatörlerini örnekleriyle çalıştım. Ayrıca bu gün itibarıyla staj boyunca uyulması gereken AI-Kullanım-Kuralları.md ve Lab-Kuralları.md dosyalarını okuyup anladım; yapay zekâyı önce kendi anlayışımı oluşturduktan sonra son doğrulama aracı olarak kullanmam, araçları mümkün olduğunca kendi makinemde ve offline çalıştırmam gerektiğini not ettim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		10

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 04.08.2026 (Salı)
<u>Yapılan iş:</u> OSI ve TCP/IP Modelleri		
Yedinci günümde ağların dilini, OSI ve TCP/IP modellerini çalıştım. OSI modelinin yedi katmanını (fiziksel, veri bağlantısı, ağ, taşıma, oturum, sunum, uygulama) görevleri ve ilişkili donanım/protokolleriyle inceledim; TCP/IP modelinin ise dört katmanlı ve OSI'nin bazı katmanlarını birleştiren daha esnek, uygulanmış bir model olduğunu öğrendim. Kapsülleme (encapsulation) kavramını - verinin üst katmandan alt katmana inerken her katmanda kendi başlığının eklenmesi, alıcı tarafta ise tersinin yapılması - somut bir örnekle (uygulama verisine sırasıyla TCP/UDP, IP, Ethernet başlığı ve FCS eklenmesi) çalıştım. TCP'nin üçlü el sıkışmasını (SYN, SYN-ACK, ACK) ve amacının bağlantıya hazır olma durumunu doğrulamak ile sıra numaralarını senkronize etmek olduğunu öğrendim. Sık kullanılan portları (21 FTP, 22 SSH, 25 SMTP, 53 DNS, 80 HTTP, 110 POP3, 143 IMAP, 443 HTTPS, 445 SMB, 3389 RDP) ve beklenmedik bir makinede açık olmalarının neden şüpheli sayılması gerektiğini bir tablo hâlinde çalıştım. Son olarak TCP ile UDP arasındaki temel farkları (bağlantı kurma, teslim garantisi, sıralama, hız) karşılaştırdım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		11

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 05.08.2026 (Çarşamba)
<u>Yapılan iş:</u> IPv4 Adresleme Yapısı		
Sekizinci günümde IPv4 adresleme yapısını inceledim. Bir IPv4 adresinin 32 bitlik, 4 oktetten oluşan bir adresleme sistemi olduğunu, adresin Network ID ve Host ID olmak üzere iki mantıksal bölümden oluştuğunu, subnet mask'in bu ayrımı belirlediğini öğrendim. IP adres sınıflarını (A, B, C genel ağlar; D multicast; E deneysel) ve IPv4 başlık yapısını çalıştım. Public ve Private IP ayrımını; public IP'nin internette benzersiz ve doğrudan erişilebilir, private IP'nin ise yalnızca yerel ağda anlamlı ve routable olmadığını öğrendim. Private IP aralıklarını (A: 10.0.0.0-10.255.255.255, B: 172.16.0.0-172.31.255.255, C: 192.168.0.0-192.168.255.255) ve DHCP çalışmadığında kullanılan APIPA aralığını (169.254.0.0/16) not ettim. Private IP kullanımının hem IP adresi tasarrufu (NAT ile birçok cihazın tek bir public IP'yi paylaşması) hem de dahili ağı doğrudan dış saldırılara karşı koruyan doğal bir bariyer oluşturması açısından önemini kavradım. Loopback ağını (127.0.0.0/8, en yaygın olarak 127.0.0.1/localhost) ve bu adrese giden trafiğin cihaz dışına çıkmadığını, bu yüzden loglarda 127.0.0.1 görülmesinin trafiğin dış ağdan değil cihazın kendisinden geldiğini gösterdiğini öğrendim. CIDR gösterimini, default gateway kavramını ve toplam/kullanılabilir host sayısını hesaplayan temel formülleri (2^n ve 2^{n-2}) çalıştım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		12

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 06.08.2026 (Perşembe)
<u>Yapılan iş:</u> Wireshark ile Ağ Trafiği Analizi(DNS/HTTPS/TLS)		
Dokuzuncu günümde Ubuntu sanal makinesine Nginx kurarak basit bir web sunucusu ayağa kaldırdım ve Windows sanal makinesinden Ubuntu'nun IP adresine bağlanarak erişimi doğruladım. Ardından Ubuntu üzerine Wireshark kurdum ve dns, http, tcp.port==443 gibi filtrelerle farklı trafik türlerini ayrı ayrı incelemeye başladım. DNS filtresiyle yakaladığım trafikte (enp0s3 arayüzü üzerinden) ads.mozilla.org, mozilla-ohttp.fastly-edge.com, connectivity-check.ubuntu.com ve firefox.settings.services.mozilla.com gibi adreslere yapılan standart sorgu/cevap paketlerini gözlemledim; her sorgunun bir cevapla eşleştiğini ve UDP üzerinden 53 numaralı porta gittiğini doğruladım. TCP Three-Way Handshake sürecini iki farklı senaryoda çalıştım. Lab arayüzünde (enp0s8) 80 portuna yaptığım bağlantıda SYN, ardından sunucudan SYN-ACK geldiğini, istemcinin son ACK'ı gecikmesi nedeniyle sunucunun SYN-ACK paketini birkaç kez tekrar (retransmission) gönderdiğini gözlemledim. İnternete açık 443 portuna yaptığım bir denemede ise SYN gönderdikten sonra karşı taraftan RST, ACK döndüğünü gördüm; bu, hedefin o portta bağlantıyı kabul etmediğini gösteriyordu - normal SYN→SYN-ACK→ACK akışından farklı bir sonuç almak, üçlü el sıkışmanın her zaman başarıyla tamamlanmayabileceğini somut olarak gösterdi. Şifreli ve şifresiz trafiği karşılaştırdım: lab ortamındaki HTTP trafiğinde (enp0s8, GET /favicon.ico isteği ve 404 Not Found yanıtı) paket içeriğinin düz metin olarak okunabildiğini gördüm. Buna karşılık gerçek internete giden HTTPS/TLS trafiğinde (enp0s3, content-signature-2.cdn.mozilla.net'e giden bir TLS 1.2 el sıkışması - Client Hello, Server Hello, Certificate, Server Key Exchange, Change Cipher Spec, Encrypted Handshake) veri hiçbir yerde düz metin olarak görünmüyordu; bu karşılaştırma HTTP ile HTTPS arasındaki farkın pratikte ne anlama geldiğini net şekilde gösterdi. Windows makinesine Nmap kurarak Ubuntu makinesi üzerinde host keşfi ve port taraması yaptım, tarama sırasında oluşan trafiği Wireshark üzerinden analiz ettim. Gerçekleştirdiğim tüm paket yakalamalarını .pcapng formatında anlamlı dosya isimleriyle kaydederek ilgili gün klasörüne yerleştirdim. Günlük Linux alıştırması olarak Bandit oyununda Level 14'e kadar ilerledim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		13

<u>İş Yeri</u>nde Çalışılan Birim: IT Departmanı - Siber Güvenlik Birimi		Tarih: 07.08.2026 (Cuma)
<u>Yapılan iş:</u> Web Sitesine Bağlanma Süreci ve İlk Trafik Analiz Raporu		
Onuncu günümde bir web sitesine bağlanma sürecinin ağ üzerinde adım adım nasıl işlediğini bütüncül olarak ele aldım. Öncelikle tarayıcıya yazılan alan adının DNS tarafından IP adresine çevrildiğini; ardından verinin TCP/IP katmanlarına göre kapsüllendiğini çalıştım. İstemci ile sunucu arasında güvenilir bağlantının TCP'nin üçlü el sıkışması ile kurulduğunu, HTTPS kullanan sitelerin 443 portu üzerinden TLS ile şifrelenmiş şekilde iletişim kurduğunu, bu sayede trafik yakalansa bile içeriğin okunamadığını pekiştirdim. Paketlerin hedefe ulaşırken switch, router ve firewall gibi ağ cihazlarından geçtiğini, sunucunun yanıtının aynı yoldan geri dönüp decapsulation ile açıldığını bir bütün olarak özetledim. Bu haftanın kavramlarının (DNS, kapsülleme, TCP el sıkışması, HTTPS/TLS, portlar, switch/router/firewall) birbirinden bağımsız değil, tek bir olayda birleşen bir zincir olduğunu görmüş oldum. Öğleden sonra lab ortamında Windows ve Ubuntu makineleri arasında ping trafiği, web sunucusu ziyareti, internete çıkan bir bağlantı ve bir nmap taraması üretip Wireshark ile yakaladım; bu yakalamalara dayanarak yakalama ortamı, gözlemler, kanıtlar, yorum ve sonuç başlıklarını içeren ilk ağ trafiği analiz raporumu hazırladım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		14

<u>İş Yerinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 10.08.2026 (Pazartesi)
<u>Yapılan iş:</u> Linux Kullanıcı, İzin ve Süreç Yönetimi		
On birinci günümde Linux'ta kullanıcı, izin ve süreç yönetimini çalıştım. /etc/passwd ve /etc/group dosyalarının kullanıcı ve grup bilgilerini tuttuğunu; /etc/shadow dosyasının hashlenmiş parolaları içerdiği için sudo yetkisi gerektirdiğini gördüm. Bir kullanıcıya sudo yetkisi verilmesinin onu yönetici seviyesine çıkardığını, bu yüzden bir SOC analistinın kimlerin sudo yetkisine sahip olduğunu takip etmesi gerektiğini kavradım. touch ile oluşturduğum bir test dosyasında ls -l çıktısını (-rw-rw-r--) inceleyerek dosya izinlerinin owner/grup/diğerleri şeklinde ayrıldığını, harflerin sayısal karşılıklarını (664) hesapladım. chmod, chown ve umask komutlarının izinleri nasıl etkilediğini, /etc/sudoers dosyasının kimin hangi komutu çalıştırabileceğini belirlediğini öğrendim. UID/GID kavramlarını, root'un UID 0 olduğunu ve bir sistemde beklenmedik şekilde UID 0 yetkisine sahip bir kullanıcı görmenin ciddi bir bulgu sayıldığını kavradım. SUID ve SGID bitlerini, find / -perm -4000 -type f komutuyla SUID'li dosyaları nasıl listeleyebileceğimi öğrendim; SUID listesinin kısa olmasının aslında güvenlik açısından iyi bir işaret olduğunu gördüm. Sticky bit'in ortak bir klasörde kullanıcıların birbirinin dosyasını silmesini engellediğini öğrendim. Son olarak PID/PPID ilişkisini ve ps, ps aux, top komutlarıyla çalışan süreçleri nasıl izleyebileceğimi uygulamalı olarak çalıştım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		15

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 11.08.2026 (Salı)
<u>Yapılan iş:</u> Linux Log Kaynakları ve Komut Satırından Analiz		
On ikinci günümde /var/log dizini altındaki log kaynaklarını ve komut satırından log analizini çalıştım. auth.log'un kimlik doğrulama olaylarını, syslog'un genel sistem olaylarını, kern.log'un çekirdek mesajlarını tuttuğunu; journalctl'in ise systemd-journald tarafından tutulan binary formatlı kayıtları okumak için kullanıldığını öğrendim. journalctl --since/--until ile zamana göre, -u ile servise göre, -p err ile önem derecesine göre filtreleme yaptım. tail -n 20 /var/log/auth.log ile incelediğim bir log satırının zaman damgası, hostname, süreç adı, PID, USER, CWD ve COMMAND alanlarını parça parça ayrıştırdım. Sistemin saat diliminin Etc/UTC olduğunu timedatectl ile doğruladım ve farklı sistemlerin logları birleştirilirken saat dilimi farklarının olay sırasını yanlış yorumlatabileceğini kavradım. grep komutunun -a, -i, -v, -c, -n seçeneklerini ve pipe () ile çıktıyı başka komutlara aktarmayı uygulamalı olarak denedim. Bir log satırındaki zaman, makine, süreç, PID ve mesaj bilgilerinin doğru ayrıştırılmasının, bir olayın ne zaman, hangi sistemde ve hangi süreç tarafından gerçekleştirildiğini belirlemek için kritik olduğunu gördüm.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		16

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 12.08.2026 (Çarşamba)
<u>Yapılan iş:</u> Windows Kullanıcı/Grup Yapısı ve Event Viewer		
On üçüncü günümde Windows'un kullanıcı ve grup yapısını Linux ile karşılaştırarak çalıştım. Yerel kullanıcı/grup bilgilerinin SAM veritabanında tutulduğunu, Users/Administrators/Administrator/Guest gruplarının rollerini ve UAC'nin yönetici yetkisi gerektiren işlemlerde ek onay istemesinin sudo'nun işlevine benzediğini gördüm. SID kavramının, kullanıcı adı değişse bile hesabın kendisine özgü kalan ve değişmeyen bir kimlik olduğunu; bu yüzden bir SOC analistinin geçmiş ve güncel olayları aynı hesapla ilişkilendirmek için SID'i kullandığını öğrendim. Event Viewer'daki Application, Security, System ve Setup günlüklerini inceledim. Önemli Event ID'leri (4624 başarılı giriş, 4625 başarısız giriş, 4634 oturum kapatma, 4720 yeni kullanıcı oluşturma, 4728/4732 gruba ekleme, 7045 yeni servis kurulumu, 1102 security logunun temizlenmesi) anlamlarıyla birlikte çalıştım. Logon Type değerlerinin (2 interactive, 3 network, 4 batch, 5 service, 7 unlock) aynı Event ID'ye farklı anlamlar kazandırdığını, bu yüzden bir girişin sadece Event ID'sine değil Logon Type'ına da bakılması gerektiğini kavradım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		17

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 13.08.2026 (Perşembe)
<u>Yapılan iş:</u> Sysmon ile Süreç ve Ağ Görünürlüğü		
On dördüncü günümde Sysmon aracını inceledim. Sysmon'un, Windows'un varsayılan loglarının yetersiz kaldığı hangi sürecin hangi komut satırıyla, hangi üst süreç tarafından başlatıldığı, hangi ağ bağlantısının kurulduğu gibi ayrıntıları kaydettiğini; kendisinin bir engelleme mekanizması değil salt bir görünürlük aracı olduğunu öğrendim. Event ID 1 (Process Create) kaydının Image, CommandLine, User, ParentImage, ParentCommandLine ve UtcTime alanlarını taşıdığını, özellikle ParentImage bilgisinin saldırı analizinde kritik olduğunu kavradım. Uygulamalı olarak: sysmon-test.txt adlı bir dosya oluşturduğumda Event ID 11 kaydının oluşmadığını fark ettim; yapılandırmayı inceleyince .txt dosyalarının filtrelendiğini, bunun Sysmon'un çalışmamasından değil yapılandırma kısıtlamasından kaynaklandığını anladım - bu bana aşırı kayıt tutmanın gürültüye, aşırı kısıtlamanın ise görünürlük kaybına yol açtığını gösterdi. Chrome üzerinden bir siteye girdiğimde Event ID 22 (DNS Query) kaydında wpad sorgusunu gördüm. Windows'tan Ubuntu'ya SSH bağlantısı kurduğumda Event ID 3 (Network Connection) kaydında hedef IP/portu gözlemledim; ardından bir nmap taraması yaptığımda kaynak makinede de nmap.exe'nin oluşturduğu bağlantı kaydını görerek hem kaynak hem hedef taraf açısından görünürlüğü karşılaştırdım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		18

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 14.08.2026 (Cuma)
<u>Yapılan iş:</u> Log Saklama, SSH Analizi ve SIEM'e Giriş		
On beşinci günümde log saklama ve log rotation mekanizmalarını çalıştım. Ubuntu'da logrotate'ın /etc/logrotate.d/rsyslog yapılandırmasıyla (weekly, rotate 4, compress, delaycompress) logları döngüye soktuğunu; bir log kaynağının saklama süresinin bir olayın ne kadar geriye dönük araştırılabileceğini doğrudan etkilediğini kavradım. Windows Security ve Sysmon Operational loglarının "Overwrite events as needed" ayarıyla dolduğunda en eski kayıtların üzerine yazıldığını öğrendim. Uygulamalı olarak Windows'tan Ubuntu'ya iki başarısız, bir başarılı SSH girişi yaptım ve bunları auth.log'da doğruladım; sudo whoami ile yetki yükselttiğimde bunun da kayıt altına alındığını gördüm. Windows tarafında iki başarısız (4625) ve bir başarılı (4624) oturum açma denedim, notepad.exe çalıştırarak Sysmon Event ID 1 kaydını inceledim. Windows'tan Ubuntu'ya yaptığım SSH bağlantısının Sysmon'da Event ID 3 kaydı üretmediğini fark ettim; bu, lab ortamındaki bir görünürlük boşluğuydu ve bir olayın gerçekleşmiş olmasına rağmen uygun yapılandırma yoksa loglardan doğrulanamayabileceğini somut olarak gösterdi. Son olarak merkezi loglama ve SIEM'in, farklı makinelerin loglarını tek noktada toplayarak analiz ve korelasyonu hızlandırdığını, ancak beraberinde veri hacmi ve normalleştirme gibi yeni zorluklar getirdiğini öğrendim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		19

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 17.08.2026 (Pazartesi)
<u>Yapılan iş:</u> Temel Saldırı Türleri		
On altıncı günümde temel saldırı türlerini çalıştım: Keşif (reconnaissance), Brute Force (bir hesaba çok sayıda parola denemesi; auth.log'da Failed password veya Windows'ta Event ID 4625 olarak görülür), Password Spraying (az sayıda yaygın parolanın çok sayıda hesapta denenmesi), Phishing, MITM/ARP Spoofing ve DoS/DDoS kavramlarını örnekleriyle inceledim. Geçen haftaki lab çalışmalarım (SSH başarısız girişler, iki makine arası iletişim) bu saldırı türleri arasında bağlantı kurdum: kontrollü olarak yaptığım başarısız SSH denemelerinin gerçek bir brute force saldırısında aynı log desenini nasıl üreteceğini gördüm. Yanal hareket (lateral movement) kavramını - saldırganın bir sistemi ele geçirdikten sonra ağdaki diğer sistemlere geçmeye çalışması - ve bunun Linux'ta auth.log, Windows'ta Sysmon Event ID 3 üzerinden nasıl izlenebileceğini öğrendim.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		20

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 18.08.2026 (Salı)
<u>Yapılan iş:</u> MITRE ATT&CK Çerçevesi		
On yedinci günümde MITRE ATT&CK çerçevesini çalıştım. Taktiğin (tactic) saldırganın ulaşmak istediği amacı, tekniğin (technique) bu amaca ulaşmak için kullandığı somut yöntemi ifade ettiğini öğrendim. Initial Access, Execution, Persistence, Privilege Escalation, Defense Evasion, Credential Access, Discovery, Lateral Movement, Collection, Exfiltration ve Impact taktiklerini örnek teknikleriyle (T1110 Brute Force, T1059 Command and Scripting Interpreter, T1098 Account Manipulation vb.) bir tabloda çalıştım. Cyber Kill Chain'in saldırıyı genel ve sıralı aşamalarla anlatan bir model olduğunu, MITRE ATT&CK'in ise saldırganın somut davranış ve tekniklerini taktikler altında sınıflandırdığını, bu ikisinin birbirini tamamladığını kavradım. Kendi lab çalışmalarımı MITRE ATT&CK ile eşleştirdim: bir hesaba yaptığım art arda başarısız giriş denemelerini Credential Access altında Brute Force (T1110), yeni bir yönetici hesabı oluşturmamı Persistence/Privilege Escalation altında Account Manipulation (T1098), sudo whoami ile yetki yükseltmemi Privilege Escalation altında Sudo and Sudo Caching (T1548.003) ile ilişkilendirdim. Bu eşleştirme, MITRE ATT&CK'in kendi çalışmalarımıdaki davranışları standart bir dile nasıl çevirdiğini somut olarak görmemi sağladı.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		21

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 19.08.2026 (Çarşamba)
<u>Yapılan iş:</u> Ağ Mimarisi ve SIEM'e Giriş		
On sekizinci günümde ağ mimarisi kavramlarını ve SIEM'e girişi çalıştım. Ağ segmentasyonunun kurumsal bir ağı bölümlere ayırarak bir bölümün ele geçirilmesi durumunda saldırganın diğer bölümlere doğrudan geçememesini sağladığını; VLAN'ın aynı fiziksel switch altyapısını yazılımsal olarak mantıksal ağlara ayırdığını; DMZ'nin dışa açık sunucuları iç ağdan izole eden bir ara bölge olduğunu; proxy'nin (forward/reverse) trafiği tek noktadan kontrol ve kayıt altına aldığını; VPN'in güvensiz bir ağ üzerinden şifreli bir tünel kurduğunu öğrendim. Her birinin bir analist için neden değerli bir log/sensör noktası olduğunu kavradım. SIEM'in farklı kaynaklardan gelen logları tek merkezde toplayıp analiz eden bir sistem olduğunu ve toplama, normalleştirme, korelasyon, alarm üretme gibi temel işlevlerini öğrendim. Bu, Gün 15'te fark ettiğim "logları tek yerde toptasak ne kazanırdık" sorusuna somut bir cevap oldu.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		22

<u>İş Yeriinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 20.08.2026 (Perşembe)
<u>Yapılan iş:</u> Splunk'a Veri Besleme ve Temel SPL Sorguları		
On dokuzuncu günümde Splunk'a veri besleme ve temel SPL sorgularını çalıştım. Ubuntu lab makinesindeki /var/log/auth.log dosyasını önce Add Data > Upload ile tek seferlik, ardından Monitor input ile sürekli izlenecek şekilde Splunk'a bağladım; staj_lab adlı yeni bir index ve staj_auth_log adlı bir sourcetype oluşturdum. SPL'i terminal komutlarıyla karşılaştırarak öğrendim: arama terimi grep'in, stats count wc -l'nin, stats count by <alan> sort uniq -c'nin, table ham logu okunabilir sütunlara indirgeyen bir komutun, rex ise awk/cut gibi manuel alan çıkarmanın karşılığıydı. Bunu uygulamalı olarak test ettim: Windows'tan Ubuntu'ya bilerek üç kez yanlış şifreyle SSH denemesi yaptım, önce grep -a "Failed password" ile bunu doğruladım, ardından Splunk'ta rex ile src_ip alanını çıkarıp stats count by src_ip sorgusuyla aynı sonuca ulaştım. Aynı soruya iki farklı araçla ulaşmak, SPL'in terminaldeki çok adımlı bir zinciri tek satırda ve daha okunabilir şekilde ifade edebildiğini gösterdi.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		23

<u>İş Yerinde Çalışılan Birim:</u> IT Departmanı - Siber Güvenlik Birimi		Tarih: 21.08.2026 (Cuma)
<u>Yapılan iş:</u> Case 1: SSH Brute Force Olay Raporu		
Yirminci ve Staj 1 döneminin son günü, ilk gerçek olay müdahale vakamı (Case 1) çalıştım. web01 sunucusunun auth.log kaydına dayanarak INC-2026-0824-01 numaralı olay raporunu hazırladım: dış bir IP adresinin (203.0.113.66) sistemde var olan ve olmayan kullanıcı adlarını sistematik olarak denediğini, 91 başarısız denemenin ardından deploy hesabıyla başarılı giriş sağladığını, girişten saniyeler sonra /etc/shadow dosyasını okuyup yeni bir kullanıcı (svc-update) oluşturduğunu SPL sorgularıyla adım adım kanıtladım. Raporumda beş temel bulguyu belgeledim: kaynak IP ve saldırı hacmi (91 deneme, otomatize bir araca işaret eden bir hız), denenen kullanıcı adları, başarılı giriş, deploy hesabının normal davranışıyla karşılaştırma (iki normal iç ağ girişinin ardından dış IP'den gelen anormal üçüncü giriş) ve giriş sonrası aktivite. Zaman çizelgesi, bulgular ve kanıtlar, etki ve öneriler başlıklarını içeren tam bir olay raporu formatında yazdım. Bu vaka, staj boyunca öğrendiğim NIST Olay Müdahale Yaşam Döngüsü'nün ve MITRE ATT&CK eşlemesinin (Brute Force T1110, Valid Accounts T1078, OS Credential Dumping T1003.008, Create Account T1136.001) ilk kez uçtan uca bir araya geldiği çalışma oldu; Staj 1 dönemini bu raporla tamamladım.		
<u>Stajyerin imzası</u>	<u>İş yeri yetkilisinin imzası</u>	<u>Sayfa no</u>
		24